

MERIDIAN Group, reference pack

Module M2-01-4-ISMS, Security Governance and Information System Mapping. Handed out in session 1, valid for all ten sessions. Version 1, 31 August 2026.

Fictional company. The people, contracts, incidents and figures in this pack were built for the purposes of the module and have no real existence. Any resemblance to an existing organisation would be coincidental.

1. The role

Each working group plays the part of the **Group CISO of MERIDIAN**, appointed six weeks ago and reporting to Executive Management. The position has just been created: no predecessor, no PSSI, no consolidated budget, no dashboard. A two-paragraph mission letter, and a first Executive Committee meeting in three months.

The Group CISO does not replace any of the four subsidiary IT managers. The role sets the common framework, arbitrates what they cannot arbitrate alone, and answers to Executive Management for the security of the group. It administers no system.

Cohort organisation. Eight working groups of two to three people. Two groups per subsidiary, working on the same subsidiary without consulting each other and comparing their results in plenary. Each group has its own instance of the group's governance tool.

GROUP	SUBSIDIARY UNDER REVIEW	INSTANCE ADDRESS
G1	MERIDIAN Santé	https://medsecure-a.lockbay.eu
G2	MERIDIAN Santé	https://medsecure-b.lockbay.eu
G3	MERIDIAN Logistique	https://translog-a.lockbay.eu
G4	MERIDIAN Logistique	https://translog-b.lockbay.eu
G5	MERIDIAN Éducation	https://educonnect-a.lockbay.eu
G6	MERIDIAN Éducation	https://educonnect-b.lockbay.eu
G7	MERIDIAN Territoires	https://cityadmin-a.lockbay.eu
G8	MERIDIAN Territoires	https://cityadmin-b.lockbay.eu

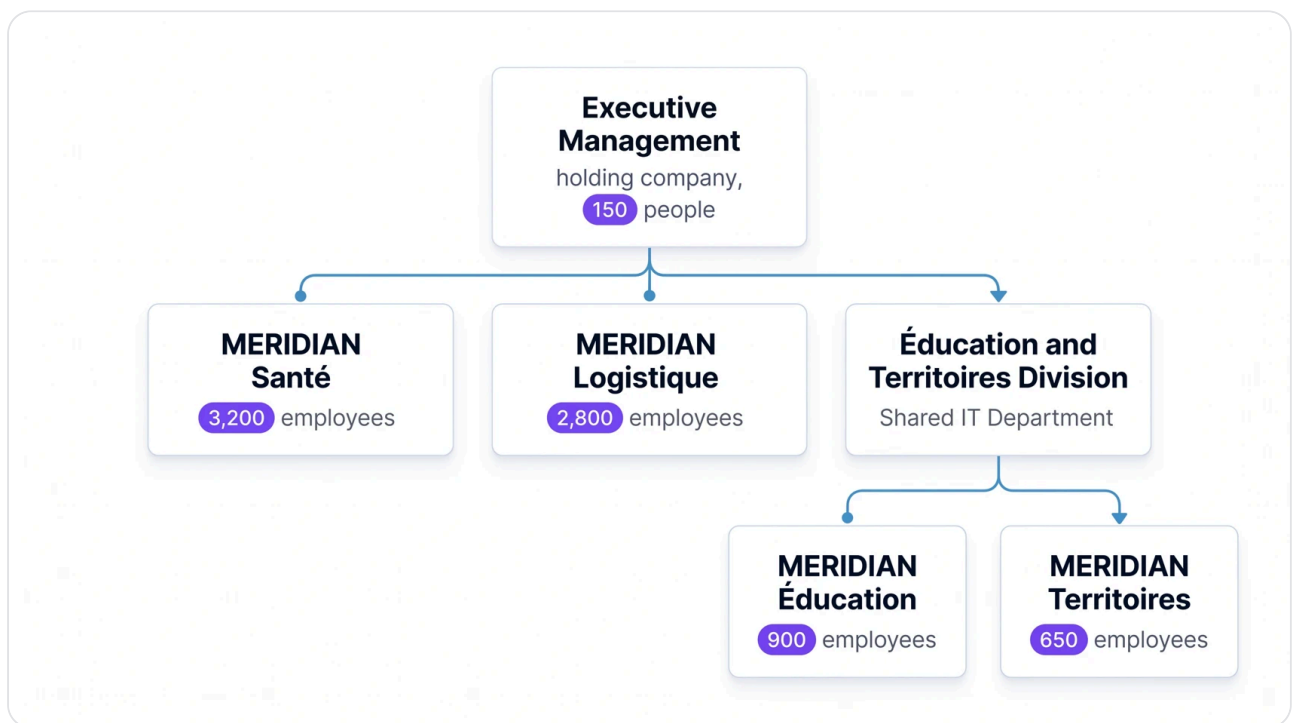
A personal deployment of CISO Assistant remains possible; the project is open source. Both routes produce the same work.

Each group reviews one subsidiary, but always writes from the Group CISO's chair: what gets written commits the group, not the subsidiary.

2. The group

MERIDIAN is a multi-sector group of **7,700 employees**, built up over eleven years through successive acquisitions. None of the four acquisitions was followed by any integration of information systems: each subsidiary kept its applications, its contracts, its providers and its habits.

- **Holding company**, 150 people at headquarters: Executive Management, Finance, HR, Legal, Internal Audit.
- **MERIDIAN Santé**, 3,200 employees, 4 care facilities.
- **MERIDIAN Logistique**, 2,800 employees, 6 warehouses.
- **MERIDIAN Éducation**, 900 employees, 45,000 user accounts.
- **MERIDIAN Territoires**, 650 employees, about thirty local authority clients.

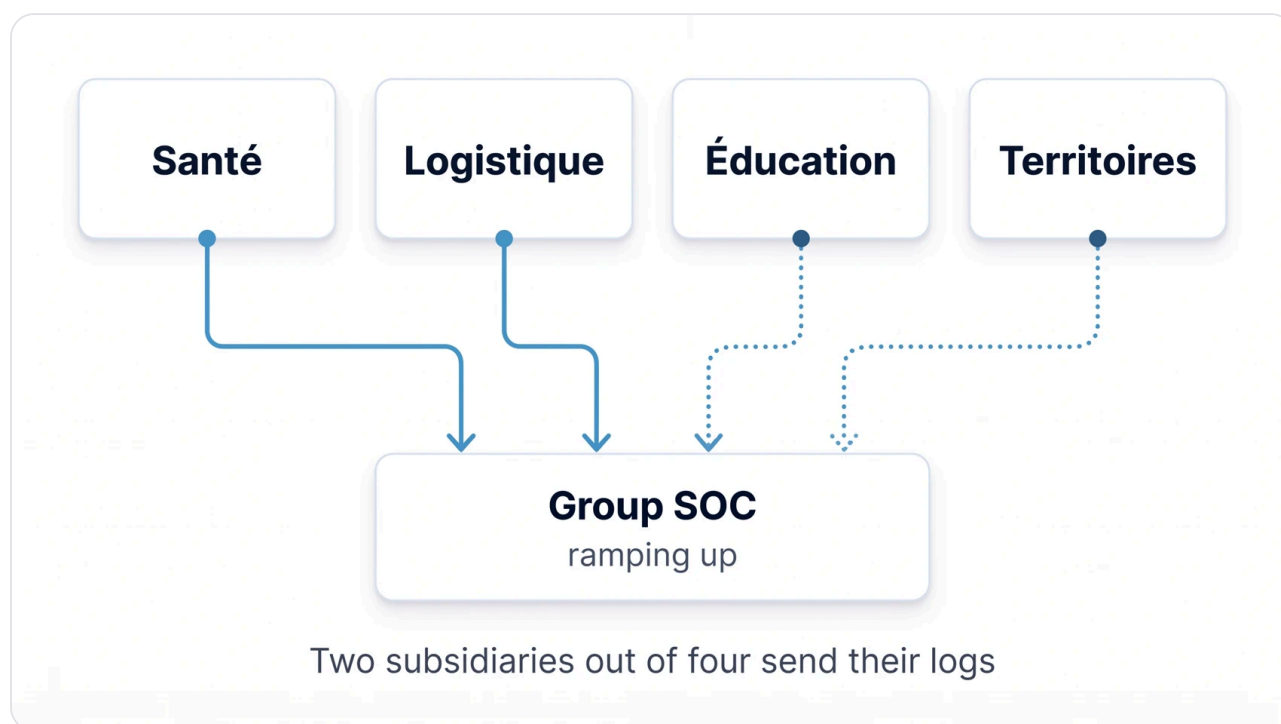


The MERIDIAN group: four subsidiaries, and one cluster with a shared IT department.

The Éducation & Territoires cluster shares a common IT department. It is the only technical consolidation ever carried out in the group, and it produces two effects present throughout the module: an identity directory common to both subsidiaries, and an IT Director who speaks for both without any written mandate to do so.

What exists today in terms of governance

A centralised SOC, **still ramping up**: it receives the logs of Santé and Logistique, not those of the Éducation & Territoires cluster. An Internal Auditor attached to the Governance and Audit function of the holding company. Four subsidiary IT managers, two of whom carry the CISO title and two of whom do not.



SOC coverage: two subsidiaries out of four send their logs.

What does not exist

No framework PSSI. No arbitration rule between subsidiaries. No security committee. No formalised risk appetite. No consolidated asset inventory. No dashboard. No security budget identified in its own right: it is buried in the subsidiaries' operating budgets.

3. The four subsidiaries

MERIDIAN Santé, 3,200 employees

Four care facilities. The fourth was acquired fourteen months ago and has never been inventoried.

Named assets. Patient records, carried by the **health data DBMS**. The **analysis machines** and **imaging consoles**. The pharmaceutical stock management system. The appointment booking portal.

Providers. The HIS vendor holds permanent remote maintenance access, through a single identifier shared between nine of its people. The hosting provider displays no HDS certification (the French health data hosting scheme); the contract merely states "compliant with applicable requirements".

Constraints. Health data hosting, medical confidentiality, continuity of the care mission.

Diagnostic findings.

1. The analysis machines and imaging consoles sit on the **office IP range**, reachable from any reception desk computer, with a **shared administration account**.
2. The business applications run on **local passwords, without multi-factor authentication**.
3. **3,940 active accounts for 3,200 staff**, including 214 belonging to leavers never deactivated, the oldest for eleven years. There is **no joiner or leaver procedure** on the IT side.
4. The subsidiary has **never handed over its register of administration accounts**, despite three requests from Internal Audit.
5. The facility acquired fourteen months ago appears in **no inventory**, connected biomedical equipment included.
6. A 4 h 10 outage in March produced 22 cancelled procedures and two patient complaints. The impact was never quantified.

MERIDIAN Logistique, 2,800 employees

Six automated warehouses, transport and warehousing under controlled temperature.

Named assets. The execution of logistics flows, carried by the **WMS** (warehouse management system) and the **automated warehouses**. The warehouse **handheld scanners**. The sorting machines. The vehicle telematics.

Providers. A third-party application maintenance provider for the WMS. An integrator for the automated systems, which connects through a 4G box placed outside the supervised network, and whose contract contains neither a reversibility clause nor any security requirement.

Constraints. Continuity of shipping, cold chain, contractual penalties of €12,000 per day of stoppage from one pharmaceutical client.

Diagnostic findings.

1. The **office and industrial networks are interconnected**, without segmentation.
2. A **domain account is shared with the third-party maintenance provider**, used by a number of people nobody can establish.
3. The service account linking the WMS to the automated systems has carried **the same password across all six warehouses since 2019**, in clear text in a configuration file.
4. The WMS backups run every day and **have never been restored** since commissioning.
5. A stoppage of more than six hours blocks **40% of the group's shipped volume**.
6. There is **no incident procedure**: during the April stoppage, everyone called whoever they could.

MERIDIAN Éducation, 900 employees

Learning platform and digital school services, 45,000 user accounts. IT department shared with Territoires.

Named assets. The **learning portal** and the **identity directory of the Éducation & Territoires cluster**, which carries the 45,000 accounts. The production database. The online payment module for extracurricular services.

Providers. Hosting is outsourced. Backup is entrusted to a second-tier subcontractor, absent from the main contract.

Constraints. Personal data of minors, GDPR at the forefront, onward subcontracting and breach notification.

Diagnostic findings.

1. The **administration accounts are shared** between the teams of the cluster's two subsidiaries, a direct consequence of the shared IT department. Nobody can say who did what.
2. The subsidiary runs on **tight resources**: its security envelope is the smallest in the group, and no hiring is planned.
3. The developers hold **read access to the production database**, "so they can debug".
4. The secure development rules exist as **pinned messages in a chat channel**.
5. The online payment module stores bank details and ships in January: the specification contains **no security requirement**.
6. The IT Director proposes to hand the security monitoring of **all four subsidiaries** to the tool he already uses, "since the IT department is already shared, we might as well centralise everything with us, it is the cheapest option".

MERIDIAN Territoires, 650 employees

Public service delegation for about thirty local authority clients. IT department shared with Éducation.

Named assets. The **citizen services platform** (online procedures of the local authority clients), backed by the **administrative databases** holding regulated citizen data. The connected street furniture operated on behalf of the local authorities: parking meters, cameras, lighting cabinets.

Providers. An outsourcer operates the street furniture estate. It holds the transaction encryption keys and **has refused in writing to hand them over**. The contract runs until 2028.

Constraints. Public procurement with imposed security clauses, regulated citizen data, a contractual incident notification deadline of twenty-four hours to the local authority.

Diagnostic findings.

1. The **logs are kept locally, without centralisation** to the group SOC. No detection, no post-incident analysis.
2. The connected street furniture estate appears in **no inventory**: the outsourcer holds the list.
3. The outsourcer **holds the encryption keys** and refuses to return them.
4. There is **no notification procedure** to the local authority, despite the contractual twenty-four hour deadline.
5. The IT manager **opposes** Éducation's learning platform project, which needs to connect to his administrative databases.
6. The regulatory requirements are **known and written** into the delegation contracts, but none is followed by any control.

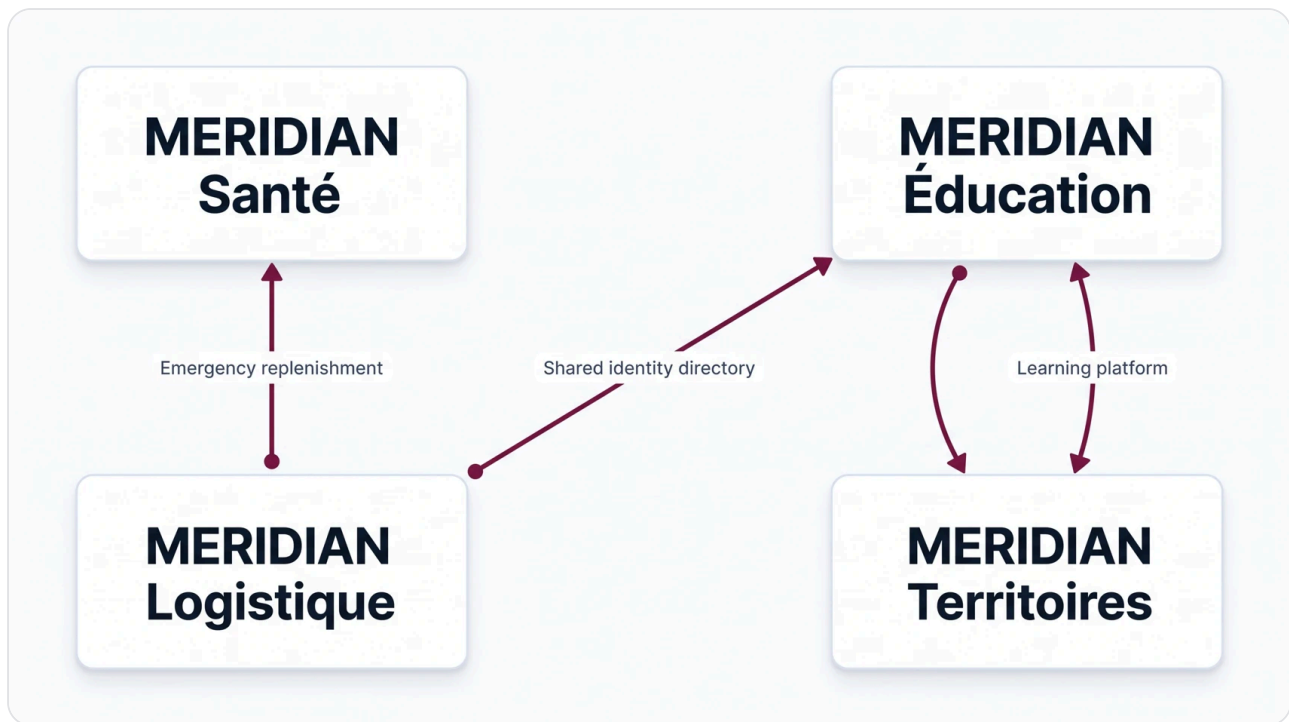
4. The findings table

To be used as is for the gap analysis and the maturity rating.

SUBSIDIARY	MAJOR FINDING	PRINCIPLE VIOLATED	WHAT IS AT STAKE
Santé	Analysis machines and imaging consoles on the office IP range, shared administration account	Isolation, least privilege	The care mission
Santé	Local passwords without multi-factor authentication	Defense in depth	Health data
Logistique	Office and industrial networks interconnected, domain account shared with the provider	Isolation, least privilege	The group's shipping continuity
Logistique	WMS backups never restored	Defense in depth	40% of shipped volume
Éducation	Shared administration accounts, in a context of tight resources	Least privilege	45,000 accounts, including minors
Éducation	Developer read access to the production database	Least privilege	Personal data
Territoires	Logs kept locally, without centralisation	Defense in depth	The evidence, and the 24 h deadline
Territoires	Encryption keys held by the outsourcer	Least privilege	Reversibility until 2028
Group	No framework PSSI and no arbitration rules	All	This is the deviation the others stem from

5. The inter-subsidiary dependencies

Three links, and they are what makes the group more than a sum of subsidiaries.



The three dependencies that make the group more than a sum of subsidiaries.

1. **Emergency replenishment from Logistique to Santé.** Logistique's warehouse handheld scanners feed Santé's stock management system, through a replenishment API on a dedicated VLAN with an inspection firewall. It is the only asset **two subsidiaries depend on**. The flow has been blocked for three months: Santé refuses, "their equipment cannot be trusted".
2. **Identity directory of the Éducation & Territoires cluster.** One directory, two subsidiaries, shared administration accounts. A compromise on one side spreads to the other.
3. **Learning platform project.** Éducation wants to connect its platform to the administrative databases of Territoires, which opposes it.

6. Eleven subscriptions outside the inventory

While compiling the inventory of the Éducation & Territoires cluster, the Éducation IT Director's team discovered **eleven subscriptions to online services taken out directly by teaching teams, outside the IT department**. Among them, a generative AI tool to which teachers submit student assessments for review. None has any contract, nor any impact assessment.

Tight budget, tens of thousands of users, a wide range of third-party software: the Éducation subsidiary combines every condition of the phenomenon. Nothing says the three other subsidiaries are free of it; they simply have not looked.

7. What Executive Management expects

A security governance common to the four subsidiaries, without stopping production, without new budget in the first year, and presentable to the Board of Directors. Executive Management set down one sentence, to keep in mind: "I do not want a report, I want to know who decides what".